ZAP by Checkmarx Scanning Report

Generated with ZAP on Wed 1 Apr 2026, at 23:30:16

ZAP Version: 2.16.1

ZAP by Checkmarx

Contents

- About this report
  - Report parameters
- Summaries
  - Alert counts by risk and confidence
  - Alert counts by site and risk
  - Alert counts by alert type
- Alerts
  - Risk=High, Confidence=Medium (1)
  - Risk=Medium, Confidence=High (1)
  - Risk=Medium, Confidence=Medium (3)
  - Risk=Low, Confidence=High (1)
  - Risk=Low, Confidence=Medium (1)

- Risk=Informational, Confidence=Medium (1)
- Risk=Informational, Confidence=Low (1)
- Appendix
  - Alert types

About this report

Report parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- `http://zero.webappsecurity.com`

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: `High`, `Medium`, `Low`, `Informational`

Excluded: None

Confidence levels

Included: `User Confirmed`, `High`, `Medium`, `Low`

Excluded: `User Confirmed`, `High`, `Medium`, `Low`, `False Positive`

Summaries

Alert counts by risk and confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
		User Confirmed	High	Medium	Low	Total
Risk	High	0 (0.0%)	0 (0.0%)	1 (11.1%)	0 (0.0%)	1 (11.1%)
	Medium	0 (0.0%)	1 (11.1%)	3 (33.3%)	0 (0.0%)	4 (44.4%)
	Low	0 (0.0%)	1 (11.1%)	1 (11.1%)	0 (0.0%)	2 (22.2%)
	Informational	0 (0.0%)	0 (0.0%)	1 (11.1%)	1 (11.1%)	2 (22.2%)
	Total	0 (0.0%)	2 (22.2%)	6 (66.7%)	1 (11.1%)	9 (100%)

Alert counts by site and risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

		Risk			
		High (= High)	Medium (>= Medium)	Low (>= Low)	Informational (>= Informational)
Site	http://zero.webappsecurity.com	1 (1)	4 (5)	2 (7)	2 (9)

Alert counts by alert type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
SQL Injection - SQLite	High	1 (11.1%)
Content Security Policy (CSP) Header Not Set	Medium	8 (88.9%)
Cross-Domain Misconfiguration	Medium	20 (222.2%)
Missing Anti-clickjacking Header	Medium	5 (55.6%)
Vulnerable JS Library	Medium	2 (22.2%)
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	20 (222.2%)
X-Content-Type-Options Header Missing	Low	17 (188.9%)
Total		9

Alert type	Risk	Count
Information Disclosure - Suspicious Comments	Informational	2 (22.2%)
Modern Web Application	Informational	3 (33.3%)
Total		9

Alerts

Risk=High, Confidence=Medium (1)

http://zero.webappsecurity.com (1)

SQL Injection - SQLite (1)

▶ GET http://zero.webappsecurity.com/resources/font/fontawesome-webfont.woff?v=3.0.1

Risk=Medium, Confidence=High (1)

http://zero.webappsecurity.com (1)

Content Security Policy (CSP) Header Not Set (1)

▶ GET http://zero.webappsecurity.com/robots.txt

Risk=Medium, Confidence=Medium (3)

http://zero.webappsecurity.com (3)

Cross-Domain Misconfiguration (1)

▶ GET http://zero.webappsecurity.com/robots.txt

Missing Anti-clickjacking Header (1)

▶ GET http://zero.webappsecurity.com

Vulnerable JS Library (1)

▶ GET http://zero.webappsecurity.com/resources/js/jquery-1.8.2.min.js

Risk=Low, Confidence=High (1)

http://zero.webappsecurity.com (1)

Server Leaks Version Information via "Server" HTTP Response Header Field (1)

▶ GET http://zero.webappsecurity.com/robots.txt

Risk=Low, Confidence=Medium (1)

http://zero.webappsecurity.com (1)

X-Content-Type-Options Header Missing (1)

▶ GET http://zero.webappsecurity.com

Risk=Informational, Confidence=Medium (1)

http://zero.webappsecurity.com (1)

Modern Web Application (1)

▶ GET http://zero.webappsecurity.com

Risk=Informational, Confidence=Low (1)

http://zero.webappsecurity.com (1)

Information Disclosure - Suspicious Comments (1)

▶ GET http://zero.webappsecurity.com/resources/js/jquery-1.8.2.min.js

Appendix

Alert types

This section contains additional information on the types of alerts in the report.

SQL Injection - SQLite

Source	raised by an active scanner (plugin ID: 40024)
CWE ID	89
WASC ID	19
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

Content Security Policy (CSP) Header Not Set

Source	raised by a passive scanner (Content Security Policy (CSP) Header Not Set)
CWE ID	693
WASC ID	15

Reference	▪ https://developer.mozilla.org/en-US/docs/Web/Security/CSP/Introducing_Content_Security_Policy ▪ https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html ▪ https://www.w3.org/TR/CSP/ ▪ https://w3c.github.io/webappsec-csp/ ▪ https://web.dev/articles/csp ▪ https://caniuse.com/#feat=contentsecuritypolicy ▪ https://content-security-policy.com/

Cross-Domain Misconfiguration

Source	raised by a passive scanner (Cross-Domain Misconfiguration)
CWE ID	264
WASC ID	14
Reference	▪ https://vulncat.fortify.com/en/detail?id=desc.config.dotnet.html5_overly_permissive_cors_policy

Missing Anti-clickjacking Header

Source	raised by a passive scanner (Anti-clickjacking Header)
CWE ID	1021
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options

Vulnerable JS Library

Source	raised by a passive scanner (Vulnerable JS Library (Powered by Retire.js))
CWE ID	1395
Reference	▪ https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/

Server Leaks Version Information via "Server" HTTP Response Header Field

Source	raised by a passive scanner (HTTP Server Response Header)
CWE ID	497
WASC ID	13
Reference	▪ https://httpd.apache.org/docs/current/mod/core.html#servertokens ▪ https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) ▪ https://www.troyhunt.com/shhh-dont-let-your-response-headers/

X-Content-Type-Options Header Missing

Source	raised by a passive scanner (X-Content-Type-Options Header Missing)
CWE ID	693
WASC ID	15
Reference	▪ https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)

- https://owasp.org/www-community/Security_Headers

Information Disclosure - Suspicious Comments

Source	raised by a passive scanner (Information Disclosure - Suspicious Comments)
CWE ID	615
WASC ID	13

Modern Web Application

Source	raised by a passive scanner (Modern Web Application)